

Bài thực hành 04

Cấu trúc Dữ liệu Động & Công cụ Phân tích Tĩnh Hệ thống SecureSys – Module Inventory (Catalog sách)

Học phần CSE703093 – An toàn phần mềm
Phenikaa University

Ngày 8 tháng 7 năm 2026

Tóm tắt nội dung

Bài thực hành cài đặt danh sách liên kết đơn (singly linked list) quản lý catalog sách, sau đó sử dụng công cụ phân tích tĩnh **cppcheck** để phát hiện lỗi **mà không cần chạy chương trình**. Sinh viên đối chiếu năng lực phát hiện của phân tích tĩnh với phân tích động (AddressSanitizer, Bài 3) để hiểu rõ vai trò bổ sung giữa hai phương pháp.

Mục lục

1 Kiến thức nền tảng	1
2 Ba lỗi tĩnh vi trong <code>booklist_v1_buggy.c</code>	1
3 Kết quả phân tích tĩnh	1
4 Kết quả kiểm thử tự động	2
5 Tài liệu tham khảo	2

1 Kiến thức nền tảng

cppcheck là công cụ phân tích tĩnh mã nguồn mở cho C/C++, duyệt AST/CFG của mã nguồn để tìm các mẫu lỗi đã biết (uninitialized variable, null pointer dereference, memory leak, ...) mà **không cần biên dịch và thực thi** chương trình – khác biệt căn bản với kiểm thử động (Bài 3, Bài 7, Bài 8).

2 Ba lỗi tĩnh vi trong booklist_v1_buggy.c

CWE	Vị trí	Mô tả
CWE-476	list_insert_node	Thiếu kiểm tra malloc() trả về NULL
CWE-401	list_remove_node	Thiếu free(cur) khi xóa node
CWE-457	list_count_nodes	Biến đếm không được khởi tạo

3 Kết quả phân tích tĩnh

```

1 [ERROR] dong 44: Uninitialized variable: count
2 [WARNING] dong 25: Memory is allocated but not initialized: node
3 -> 2 finding lien quan bao mat (error/warning) tren ban buggy
4 -> 0 finding lien quan bao mat tren ban fixed

```

Listing 1: Trích kết quả cppcheck (-enable=all -inconclusive)

Nhận xét quan trọng: cppcheck phát hiện tốt lỗi uninitialized variable và uninitialized data, nhưng **không** luôn phát hiện được lỗi memory leak có luồng điều khiển phức tạp (nhiều nhánh return) – đây là lý do phân tích động (ASan) vẫn cần thiết như một lớp phòng thủ bổ sung.

4 Kết quả kiểm thử tự động

tests/test_static_analysis.py thực hiện 5 test: biên dịch/chạy đúng cả 2 phiên bản, cppcheck phát hiện ≥ 2 lỗi ở bản buggy, 0 lỗi ở bản fixed, và đối chiếu baseline. **Kết quả: 5/5 test PASS.**

Mục tiêu học tập

- Cài đặt và thao tác trên danh sách liên kết đơn cấp phát động.
- Sử dụng cppcheck để phát hiện lỗi không cần chạy chương trình.
- Đọc hiểu báo cáo XML, phân biệt mức độ error/warning/style/information.
- Hiểu giới hạn của phân tích tĩnh so với phân tích động.

Yêu cầu hoàn thiện

1. Bảng đối chiếu lỗi tự tìm bằng mắt vs. lỗi cppcheck phát hiện.
2. Bản tự sửa lỗi kèm log cppcheck xác nhận 0 finding.
3. Lập luận trade-off giữa cppcheck (tĩnh) và ASan (động) cho pipeline CI/CD.

Yêu cầu kết quả

tests/test_static_analysis.py toàn bộ 5 test PASS; bản fixed đạt 0 finding cppcheck mức error/warning.

5 Tài liệu tham khảo

- Đề cương CSE703093 – An toàn phần mềm, Chương 2 (2.2, 2.5).
- cppcheck.sourceforge.io – tài liệu chính thức.
- CWE-457, CWE-401, CWE-476 (cwe.mitre.org).